

IMPLEMENTASI ZERO TRUST ARCHITECTURE SEBAGAI STRATEGI ADAPTIF PENINGKATAN KEAMANAN SISTEM INFORMASI BERBASIS WEB

Dea Ajeng Aulia¹

¹Program Studi D3 Teknik Informatika, Politeknik Purbaya Tegal

Email: deaaulia326@gmail.com

Abstrak

Meningkatnya ransomware, kebocoran data, dan ancaman internal yang dipicu oleh adopsi komputasi awan dan kerja jarak jauh telah mengungkap keterbatasan model keamanan perimeter tradisional yang mengandalkan kepercayaan implisit terhadap jaringan internal. Penelitian ini menganalisis penerapan Zero Trust Architecture (ZTA) sebagai pendekatan alternatif berbasis prinsip “never trust, always verify” untuk mengamankan sistem informasi berbasis web. Metode kualitatif digunakan melalui studi literatur, analisis komparatif, dan penilaian risiko terhadap kerangka kerja NIST SP 800-207, ISO/IEC 27001:2022, dan CIS Controls v8. Hasil penelitian menunjukkan bahwa ZTA secara signifikan meningkatkan efektivitas kontrol keamanan pada aspek autentikasi, otorisasi, dan akuntabilitas dibandingkan model tradisional, serta menawarkan mitigasi risiko yang lebih adaptif terhadap ancaman kontemporer.

Kata Kunci: Zero Trust Architecture; keamanan siber; sistem informasi web; kontrol akses; manajemen risiko

1. PENDAHULUAN

Transformasi digital yang berlangsung pesat pada dekade terakhir telah mendorong hampir seluruh organisasi untuk menempatkan sistem informasi berbasis web sebagai tulang punggung operasional mereka. Namun, perluasan permukaan serangan (attack surface) yang menyertai transformasi tersebut turut meningkatkan frekuensi dan kompleksitas insiden keamanan siber. Data dari laporan industri menunjukkan bahwa rata-rata biaya global akibat kebocoran data mencapai titik tertinggi sepanjang masa pada tahun 2023, dengan waktu identifikasi insiden yang cenderung memanjang seiring meningkatnya kecanggihan teknik serangan (Lallie et al., 2021). Ransomware, sebagai salah satu vektor serangan paling merugikan, terus menunjukkan tren peningkatan baik dari sisi frekuensi maupun besaran kerugian finansial yang ditimbulkan, sementara serangan rekayasa sosial dan phishing tetap menjadi titik masuk utama bagi pelaku ancaman untuk mengeksploitasi kelemahan manusia sebagai mata rantai keamanan yang paling rentan (Alkhalil et al., 2021).

Selain ancaman eksternal, organisasi juga dihadapkan pada risiko insider threat yang bersumber dari penyalahgunaan hak akses oleh pengguna internal, baik yang dilakukan secara

sengaja maupun akibat kelalaian. Insider threat menjadi tantangan tersendiri karena pelakunya telah memiliki kredensial dan tingkat kepercayaan tertentu di dalam sistem, sehingga sulit dideteksi menggunakan mekanisme keamanan berbasis perimeter konvensional (Bin Sarhan & Altwaijry, 2023). Kondisi ini diperparah oleh migrasi masif organisasi menuju layanan komputasi awan yang menghadirkan tantangan keamanan baru terkait konfigurasi yang keliru, manajemen identitas lintas penyedia layanan, dan hilangnya batas jaringan yang jelas (Abdulsalam & Hedabou, 2022; Ahmed et al., 2022).

Pergeseran pola kerja menuju model kerja jarak jauh (remote working), yang semakin masif sejak pandemi COVID-19, turut memperluas titik rawan keamanan karena perangkat dan jaringan yang digunakan pekerja berada di luar kendali langsung infrastruktur TI organisasi. Studi menunjukkan bahwa insiden kebocoran data yang melibatkan faktor kerja jarak jauh cenderung menimbulkan biaya pemulihan yang lebih tinggi dibandingkan insiden pada lingkungan kerja konvensional, serta memperlihatkan bahwa faktor manusia—kelalaian, kurangnya kesadaran digital, dan tekanan kondisi kerja yang berubah—menjadi penyebab dominan terjadinya insiden keamanan pada lingkungan kerja terdistribusi (Alsharif et al., 2022; Lallie et al., 2021).

Model keamanan tradisional yang berbasis perimeter (perimeter-based security) mengasumsikan bahwa segala sesuatu yang berada di dalam batas jaringan organisasi dapat dipercaya, sementara ancaman diasumsikan berasal dari luar jaringan. Asumsi ini terbukti tidak lagi memadai pada lanskap ancaman kontemporer, di mana batas jaringan menjadi kabur akibat adopsi layanan awan, perangkat mobile, dan akses jarak jauh. Begitu penyerang berhasil menembus perimeter, mereka cenderung memiliki keleluasaan bergerak secara lateral (lateral movement) di dalam jaringan internal tanpa hambatan verifikasi tambahan (Syed et al., 2022; Buck et al., 2021). Kelemahan struktural inilah yang mendorong munculnya paradigma Zero Trust Architecture (ZTA), yakni kerangka keamanan yang mengharuskan setiap permintaan akses—baik yang berasal dari dalam maupun luar jaringan—untuk diverifikasi secara eksplisit dan berkelanjutan tanpa memberikan kepercayaan implisit kepada entitas mana pun (Rose et al., 2020).

National Institute of Standards and Technology (NIST) melalui NIST SP 800-207 telah menetapkan prinsip-prinsip dasar ZTA yang menekankan proteksi berbasis sumber daya (resource-centric) dengan identitas sebagai kontrol utama, dipadukan dengan penilaian postur perangkat serta konteks akses secara dinamis (Rose et al., 2020). Perkembangan lanjutan berupa NIST SP 800-207A memperluas prinsip tersebut ke lingkungan aplikasi cloud-native dan multi-cloud, dengan penekanan pada kebijakan otorisasi tingkat aplikasi (Chandramouli & Butcher, 2023). Berbagai kajian literatur sistematis mengonfirmasi bahwa adopsi ZTA mengalami percepatan signifikan sejak tahun 2020 seiring meningkatnya insiden berskala besar seperti serangan rantai pasok SolarWinds dan

eksploitasi Microsoft Exchange Server, yang menegaskan urgensi transformasi arsitektur keamanan menuju model yang lebih adaptif (Syed et al., 2022).

Berdasarkan uraian di atas, penelitian ini bertujuan untuk menganalisis secara komprehensif implementasi Zero Trust Architecture dalam konteks peningkatan keamanan sistem informasi berbasis web. Secara spesifik, penelitian ini bertujuan untuk: (1) menganalisis penerapan prinsip dan komponen Zero Trust Architecture pada sistem informasi berbasis web; (2) mengidentifikasi kelemahan mendasar model keamanan tradisional berbasis perimeter; (3) melakukan analisis komparatif antara pendekatan Zero Trust dan pendekatan perimeter security konvensional; (4) mengevaluasi efektivitas Zero Trust Architecture dalam melindungi aspek kerahasiaan, integritas, dan ketersediaan sistem informasi; serta (5) merumuskan rekomendasi implementasi Zero Trust Architecture yang dapat diadopsi organisasi berdasarkan kerangka kerja NIST SP 800-207, ISO/IEC 27001:2022, ISO/IEC 27002, NIST Cybersecurity Framework (CSF) 2.0, dan CIS Controls v8.

Kebaruan (novelty) penelitian ini terletak pada pengintegrasian analisis risiko kuantitatif-kualitatif dengan pemetaan silang lintas kerangka kerja (NIST SP 800-207, ISO/IEC 27001:2022, NIST CSF 2.0, dan CIS Controls v8) ke dalam satu model evaluasi efektivitas yang koheren, dilengkapi dengan roadmap implementasi bertahap yang dapat diadaptasi oleh organisasi dengan tingkat kematangan keamanan yang berbeda-beda. Kontribusi praktis penelitian ini diharapkan dapat menjadi rujukan bagi praktisi keamanan informasi dan pengambil kebijakan TI dalam merancang strategi transisi menuju arsitektur tanpa kepercayaan implisit secara bertahap dan terukur.

2. METODE

Penelitian ini menggunakan pendekatan kualitatif deskriptif-analitis dengan strategi studi literatur (literature study), analisis komparatif (comparative analysis), penilaian risiko (risk assessment), dan analisis kerangka kerja (framework analysis). Pendekatan kualitatif dipilih karena tujuan penelitian bersifat eksploratif-evaluatif terhadap konsep, prinsip, dan efektivitas penerapan Zero Trust Architecture, bukan pengujian hipotesis statistik terhadap populasi tertentu. Sumber data primer penelitian berupa dokumen standar dan kerangka kerja resmi (NIST SP 800-207, NIST SP 800-207A, ISO/IEC 27001:2022, ISO/IEC 27002, NIST CSF 2.0, dan CIS Controls v8), dilengkapi dengan artikel jurnal ilmiah terindeks Scopus dan basis data bereputasi (IEEE Xplore, Elsevier, Springer, MDPI, dan Emerald) yang terbit pada rentang tahun 2021–2026.

Penelitian dilaksanakan melalui tujuh tahapan sistematis sebagai berikut:

No	Tahapan Penelitian	Deskripsi Kegiatan
1	Identifikasi Permasalahan	Merumuskan kesenjangan (gap) antara ancaman keamanan siber kontemporer dan keterbatasan model keamanan perimeter tradisional pada sistem informasi berbasis web.
2	Studi Literatur	Menelusuri dan mengkaji artikel jurnal ilmiah, standar internasional, serta laporan teknis terkait Zero Trust Architecture yang terbit pada rentang tahun 2021–2026.
3	Pengumpulan Data	Mengumpulkan data sekunder berupa taksonomi ancaman, statistik insiden keamanan, serta spesifikasi teknis komponen ZTA dari sumber-sumber yang telah diverifikasi.
4	Analisis Framework Zero Trust	Melakukan pemetaan prinsip dan komponen ZTA (identity and access management, micro-segmentation, continuous monitoring, policy enforcement point, dan policy decision point) terhadap kerangka kerja NIST SP 800-207.
5	Analisis Risiko	Melakukan penilaian risiko kualitatif terhadap ancaman siber yang relevan menggunakan matriks kemungkinan (likelihood) dan dampak (impact) untuk memperoleh tingkat risiko relatif.
6	Evaluasi	Mengevaluasi efektivitas komparatif antara model keamanan tradisional dan Zero Trust Architecture terhadap prinsip Confidentiality, Integrity, Availability (CIA Triad), autentikasi, otorisasi, akuntabilitas, dan non-repudiation.
7	Penyusunan Rekomendasi	Merumuskan rekomendasi implementasi bertahap (roadmap jangka pendek, menengah, dan panjang) berdasarkan hasil analisis dan praktik terbaik dari kerangka kerja acuan.

Tabel 1. Tahapan Metodologi Penelitian

Analisis risiko dalam penelitian ini menggunakan pendekatan penilaian kualitatif berskala ordinal (rendah–sedang–tinggi–kritis) yang mengacu pada kombinasi tingkat kemungkinan (likelihood) dan tingkat dampak (impact) sebagaimana lazim digunakan dalam manajemen risiko keamanan informasi berbasis ISO/IEC 27005 dan NIST Risk Management Framework. Analisis komparatif dilakukan dengan membandingkan karakteristik arsitektural, mekanisme kontrol akses, dan tingkat resiliensi antara model perimeter tradisional dan Zero Trust Architecture berdasarkan sintesis temuan dari berbagai kajian literatur sistematis terdahulu (Syed et al., 2022; Buck et al., 2021; Soni et al., 2026).

3. HASIL DAN PEMBAHASAN

3.1 Kelemahan Model Keamanan Tradisional Berbasis Perimeter

Model keamanan perimeter tradisional dibangun di atas asumsi dasar bahwa ancaman berasal dari luar jaringan, sementara entitas yang telah berhasil melewati perimeter (firewall, VPN gateway, atau proxy) dianggap dapat dipercaya secara implisit. Asumsi tersebut menciptakan pola keamanan “keras di luar, lunak di dalam” (hard shell, soft interior) yang rentan terhadap eksploitasi begitu penyerang berhasil menembus lapisan pertahanan terluar. Begitu berada di dalam jaringan,

penyerang memiliki keleluasaan relatif untuk melakukan pergerakan lateral menuju aset-aset bernilai tinggi tanpa mekanisme verifikasi tambahan yang memadai (Syed et al., 2022).

Analisis literatur menunjukkan bahwa kelemahan model perimeter semakin nyata pada tiga kondisi utama: pertama, adopsi komputasi awan yang menghilangkan batas jaringan fisik yang jelas sehingga sumber daya organisasi tersebar pada berbagai penyedia layanan dengan model tanggung jawab bersama (shared responsibility) yang kompleks (Abdulsalam & Hedabou, 2022); kedua, meluasnya praktik kerja jarak jauh yang menyebabkan perangkat pengguna mengakses sumber daya organisasi dari jaringan yang berada di luar kendali langsung tim keamanan TI (Alsharif et al., 2022); dan ketiga, meningkatnya ancaman insider yang secara definitif tidak dapat dimitigasi oleh kontrol perimeter karena pelakunya telah berada di dalam batas kepercayaan jaringan (Bin Sarhan & Altwaijry, 2023). Kondisi-kondisi ini secara kolektif menegaskan perlunya pergeseran paradigma dari kepercayaan berbasis lokasi jaringan menuju verifikasi berbasis identitas dan konteks yang berkelanjutan.

3.2 Konsep dan Prinsip Zero Trust Architecture

Zero Trust Architecture merupakan paradigma keamanan yang menghilangkan kepercayaan implisit terhadap pengguna, perangkat, dan layanan hanya berdasarkan lokasi jaringan, afiliasi, atau kepemilikan (Rose et al., 2020). Prinsip fundamental ZTA yang dikenal sebagai “never trust, always verify” mengharuskan setiap permintaan akses dievaluasi secara eksplisit berdasarkan identitas, postur keamanan perangkat, konteks permintaan, dan tingkat sensitivitas sumber daya yang diakses, terlepas dari apakah permintaan tersebut berasal dari dalam maupun luar jaringan organisasi (Khan, 2023). NIST SP 800-207 merumuskan tujuh tenet dasar ZTA, di antaranya bahwa seluruh sumber data dan layanan komputasi dianggap sebagai sumber daya, seluruh komunikasi diamankan terlepas dari lokasi jaringan, dan akses terhadap setiap sumber daya diberikan secara per-sesi berdasarkan kebijakan yang dinamis (Rose et al., 2020).

Kajian sistematis terhadap literatur ZTA mengidentifikasi tiga pendekatan utama dalam merealisasikan arsitektur ini, yaitu penguatan tata kelola identitas (enhanced identity governance), segmentasi mikro (micro-segmentation), dan infrastruktur jaringan berbasis Software Defined Perimeter (SDP) (Syed et al., 2022). Ketiga pendekatan tersebut tidak bersifat mutually exclusive, melainkan lazim diimplementasikan secara komplementer untuk menghasilkan lapisan pertahanan berlapis (defense in depth) yang lebih resilien dibandingkan pendekatan tunggal.

3.3 Komponen Utama Zero Trust Architecture

Identity and Access Management (IAM). IAM menjadi fondasi ZTA karena identitas—bukan lagi lokasi jaringan—menjadi perimeter kontrol yang baru. Sistem IAM modern mengintegrasikan manajemen siklus hidup identitas, autentikasi berbasis risiko, serta kemampuan

deteksi anomali berbasis kecerdasan buatan untuk mengenali pola akses yang menyimpang dari perilaku normal pengguna.

Multi-Factor Authentication (MFA). MFA mewajibkan verifikasi identitas melalui kombinasi minimal dua faktor berbeda—sesuatu yang diketahui, dimiliki, atau melekat pada pengguna—sehingga secara signifikan menurunkan risiko akses tidak sah meskipun salah satu faktor kredensial telah disusupi. Kajian sistematis terhadap mekanisme MFA pada infrastruktur cloud menunjukkan bahwa kombinasi faktor biometrik dengan faktor kepemilikan perangkat memberikan keseimbangan optimal antara tingkat keamanan dan kemudahan penggunaan (Otta et al., 2023).

Least Privilege Access. Prinsip ini membatasi hak akses setiap entitas hanya pada sumber daya yang secara spesifik diperlukan untuk menjalankan fungsinya, sehingga meminimalkan permukaan serangan yang dapat dieksploitasi apabila kredensial suatu entitas disusupi.

Micro-Segmentation. Segmentasi mikro membagi jaringan menjadi zona-zona kecil yang terisolasi secara logis dengan kebijakan akses granular pada setiap segmen, sehingga membatasi kemampuan pergerakan lateral penyerang apabila salah satu segmen berhasil disusupi. Pendekatan ini terbukti efektif menekan penyebaran insiden pada lingkungan cloud dan kontainerisasi karena memungkinkan penerapan kebijakan keamanan pada tingkat beban kerja individual, bukan hanya pada tingkat jaringan secara keseluruhan (Dhiman et al., 2024).

Continuous Monitoring dan Continuous Authentication. Berbeda dengan model autentikasi satu kali di awal sesi, ZTA menerapkan verifikasi identitas dan postur keamanan yang berkelanjutan sepanjang sesi berlangsung, dengan memanfaatkan sinyal kontekstual seperti lokasi, waktu akses, dan pola perilaku pengguna untuk menyesuaikan hak akses secara dinamis dan real-time (Matiushin & Korkhov, 2023).

Device Trust. Selain identitas pengguna, ZTA turut mengevaluasi postur keamanan perangkat—meliputi status patch, kepatuhan konfigurasi, dan indikator kompromi—sebagai bagian dari keputusan otorisasi akses, sehingga perangkat yang tidak memenuhi standar keamanan minimum dapat ditolak atau dibatasi aksesnya.

Data Protection. Perlindungan data pada ZTA diterapkan melalui enkripsi data baik dalam kondisi transit maupun tersimpan (data at rest), klasifikasi sensitivitas data, serta penerapan kebijakan pencegahan kebocoran data (data loss prevention) yang terintegrasi dengan kebijakan akses berbasis atribut.

Policy Decision Point (PDP) dan Policy Enforcement Point (PEP). NIST SP 800-207 mendefinisikan komponen logis inti ZTA berupa Policy Engine dan Policy Administrator yang secara kolektif berfungsi sebagai PDP untuk mengevaluasi dan memutuskan kebijakan akses

berdasarkan sinyal kontekstual, serta Policy Enforcement Point yang bertugas menerapkan keputusan tersebut pada titik akses sumber daya (Rose et al., 2020). Pemisahan fungsi pengambilan keputusan dan penegakan kebijakan ini memungkinkan evaluasi akses yang konsisten dan terpusat, sekaligus penegakan yang terdistribusi pada berbagai titik akses di seluruh sistem informasi.

3.4 Hasil Analisis Risiko

Analisis risiko dilakukan terhadap delapan kategori ancaman utama yang relevan dengan sistem informasi berbasis web berdasarkan sintesis temuan literatur. Tabel 2 menyajikan hasil penilaian kualitatif terhadap tingkat kemungkinan (likelihood), tingkat dampak (impact), dan tingkat risiko gabungan dari masing-masing kategori ancaman.

No	Jenis Ancaman	Kemungkinan	Dampak	Tingkat Risiko
1	Serangan phishing dan rekayasa sosial	Tinggi	Sedang	Tinggi
2	Ransomware	Sedang	Kritis	Kritis
3	Insider threat (penyalahgunaan hak akses)	Sedang	Tinggi	Tinggi
4	Kebocoran data akibat kesalahan konfigurasi cloud	Tinggi	Tinggi	Kritis
5	Pencurian kredensial / serangan brute force	Tinggi	Sedang	Tinggi
6	Pergerakan lateral pasca-kompromi (lateral movement)	Sedang	Kritis	Tinggi
7	Man-in-the-middle pada akses jarak jauh	Rendah	Tinggi	Sedang
8	Akses API tidak sah / tidak terautentikasi	Sedang	Tinggi	Tinggi

Tabel 2. Matriks Analisis Risiko Ancaman Keamanan Sistem Informasi Berbasis Web

Hasil analisis menunjukkan bahwa ransomware dan kebocoran data akibat kesalahan konfigurasi cloud menempati kategori risiko kritis, sejalan dengan temuan bahwa biaya rata-rata insiden ransomware terus meningkat dan insiden yang melibatkan konfigurasi cloud yang keliru berkontribusi signifikan terhadap total insiden kebocoran data (Abdulsalam & Hedabou, 2022; Ahmed et al., 2022). Insider threat dan pergerakan lateral pasca-kompromi turut berada pada kategori risiko tinggi, yang secara langsung mengonfirmasi relevansi penerapan prinsip least privilege dan micro-segmentation sebagai mekanisme mitigasi utama dalam kerangka Zero Trust.

3.5 Perbandingan Model Keamanan Tradisional dan Zero Trust Architecture

Aspek	Keamanan Tradisional (Perimeter-based)	Zero Trust Architecture
Asumsi kepercayaan	Kepercayaan implisit terhadap entitas di dalam perimeter jaringan	Tidak ada kepercayaan implisit; verifikasi eksplisit pada setiap permintaan akses
Fokus kontrol	Berbasis lokasi dan segmen jaringan (network-centric)	Berbasis identitas dan sumber daya (resource-centric)

Aspek	Keamanan Tradisional (Perimeter-based)	Zero Trust Architecture
Segmentasi jaringan	Segmentasi kasar pada level perimeter/VLAN	Segmentasi mikro pada level beban kerja individual
Autentikasi	Umumnya satu kali di awal sesi (static)	Berkelanjutan dan adaptif sepanjang sesi (continuous)
Monitoring	Terbatas pada titik masuk/keluar perimeter	Menyeluruh terhadap seluruh lalu lintas internal dan eksternal
Mitigasi insider threat	Rendah, karena entitas internal dianggap tepercaya	Tinggi, karena seluruh entitas diverifikasi tanpa memandang lokasi
Kesesuaian dengan lingkungan cloud dan hybrid	Rendah; asumsi batas jaringan tetap kurang relevan	Tinggi; dirancang untuk lingkungan tanpa batas jaringan tetap
Penerapan least privilege	Umumnya statis dan jarang ditinjau ulang	Dinamis, dievaluasi berkelanjutan berdasarkan konteks

Tabel 3. Perbandingan Karakteristik Model Keamanan Tradisional dan Zero Trust Architecture

Tabel 3 menegaskan bahwa perbedaan mendasar antara kedua model tidak terletak pada teknologi yang digunakan semata, melainkan pada perubahan filosofis mengenai lokus kepercayaan. Model tradisional menempatkan kepercayaan pada batas jaringan, sementara Zero Trust menempatkan kepercayaan pada hasil verifikasi identitas dan konteks yang dievaluasi secara berkelanjutan (Buck et al., 2021; Soni et al., 2026).

[PLACEHOLDER GAMBAR — Gambar 1. Diagram Alur Keputusan Akses pada Zero Trust Architecture]

Ilustrasi alur permintaan akses dari subjek (pengguna/perangkat) melalui Policy Enforcement Point menuju Policy Decision Point (Policy Engine dan Policy Administrator), dilengkapi sumber data kontekstual (CDM, threat intelligence, log aktivitas, kebijakan kepatuhan) sebagaimana didefinisikan pada NIST SP 800-207.

Gambar 1. Diagram Alur Keputusan Akses pada Zero Trust Architecture

3.6 Tingkat Ancaman Berdasarkan Domain Sistem

Tabel 4 menyajikan pemetaan tingkat ancaman pada masing-masing domain sistem informasi berbasis web beserta skor risiko dan prioritas mitigasinya, sebagai dasar penentuan urutan implementasi kontrol Zero Trust.

Domain Sistem	Contoh Ancaman	Tingkat Ancaman	Prioritas Mitigasi
Lapisan aplikasi web (application layer)	Injeksi SQL, Cross-Site Scripting, API abuse	Tinggi	1
Lapisan identitas (identity layer)	Pencurian kredensial, credential stuffing	Kritis	1

Domain Sistem	Contoh Ancaman	Tingkat Ancaman	Prioritas Mitigasi
Lapisan jaringan (network layer)	Lateral movement, sniffing lalu lintas internal	Tinggi	2
Lapisan perangkat (endpoint layer)	Malware, perangkat tidak terkelola (BYOD)	Sedang	3
Lapisan data (data layer)	Eksfiltrasi data, akses tidak sah terhadap basis data	Kritis	1
Lapisan cloud/infrastruktur	Kesalahan konfigurasi, hak akses berlebih (over-privileged)	Tinggi	2

Tabel 4. Pemetaan Tingkat Ancaman pada Domain Sistem Informasi Berbasis Web

3.7 Kontrol Keamanan Berdasarkan CIS Controls v8

CIS Controls v8 menyediakan seperangkat praktik terbaik yang dapat dipetakan langsung terhadap prinsip Zero Trust Architecture. Tabel 5 menyajikan kontrol-kontrol CIS yang paling relevan beserta bentuk implementasinya dalam konteks ZTA.

Kontrol CIS	Nama Kontrol	Relevansi dan Implementasi terhadap ZTA
CIS Control 4	Configuration Management perangkat dan aplikasi	Penilaian postur keamanan perangkat sebagai syarat otorisasi akses (device trust)
CIS Control 5	Account Management	Manajemen siklus hidup identitas terpusat dalam sistem IAM
CIS Control 6	Access Control Management	Penerapan least privilege access dan role/attribute-based access control
CIS Control 8	Audit Log Management	Pencatatan dan analisis log akses untuk continuous monitoring
CIS Control 12	Network Infrastructure Management	Implementasi micro-segmentation dan software-defined perimeter
CIS Control 13	Network Monitoring and Defense	Deteksi anomali lalu lintas internal secara real-time
CIS Control 16	Application Software Security	Penegakan kebijakan akses pada lapisan aplikasi web (PEP tingkat aplikasi)

Tabel 5. Pemetaan CIS Controls v8 terhadap Komponen Zero Trust Architecture

3.8 Pemetaan Implementasi Lintas Kerangka Kerja

Untuk memastikan koherensi implementasi, penelitian ini memetakan pilar fungsional Zero Trust terhadap kerangka kerja NIST SP 800-207, ISO/IEC 27001:2022, NIST CSF 2.0, dan CIS Controls v8 sebagaimana disajikan pada Tabel 6.

Pilar ZTA (NIST SP 800-207)	Implementasi Teknis	ISO/IEC 27001:2022	NIST CSF 2.0	CIS Controls v8
Identitas (Identity)	Policy Engine – atribut identitas	Annex A.5.15, A.5.16	Fungsi Protect (PR.AA)	Kontrol 5, 6

Pilar ZTA (NIST SP 800-207)	Implementasi Teknis	ISO/IEC 27001:2022	NIST CSF 2.0	CIS Controls v8
Perangkat (Device)	Sinyal postur perangkat (CDM)	Annex A.8.1	Fungsi Protect (PR.PS)	Kontrol 1, 4
Jaringan (Network)	Micro-segmentation, SDP	Annex A.8.20, A.8.22	Fungsi Protect (PR.IR)	Kontrol 12, 13
Aplikasi & Beban Kerja	Policy Enforcement Point aplikasi	Annex A.8.25, A.8.26	Fungsi Protect (PR.PS)	Kontrol 16
Data	Klasifikasi & enkripsi data	Annex A.8.10, A.8.24	Fungsi Protect (PR.DS)	Kontrol 3
Visibilitas & Analitik	Continuous monitoring	Annex A.8.16	Fungsi Detect (DE.CM)	Kontrol 8, 13
Otomasi & Orkestrasi	Respons kebijakan dinamis	Annex A.5.24–A.5.28	Fungsi Respond (RS.MA)	Kontrol 17

Tabel 6. Pemetaan Silang Implementasi Zero Trust Architecture terhadap Kerangka Kerja Keamanan Informasi

[PLACEHOLDER GAMBAR — Gambar 2. Diagram Arsitektur Sistem Informasi Berbasis Web dengan Penerapan Zero Trust]

Ilustrasi arsitektur multi-lapis yang menggambarkan segmentasi mikro pada lapisan aplikasi dan basis data, gateway identitas terpusat (Identity Provider dan MFA), Policy Enforcement Point pada setiap titik akses layanan, serta modul continuous monitoring dan analitik keamanan yang terhubung ke Security Operations Center (SOC).

Gambar 2. Diagram Arsitektur Sistem Informasi Berbasis Web dengan Penerapan Zero Trust

3.9 Evaluasi Efektivitas Zero Trust Architecture

Evaluasi efektivitas dilakukan terhadap prinsip-prinsip fundamental keamanan informasi—Confidentiality, Integrity, Availability (CIA Triad), autentikasi, otorisasi, akuntabilitas, dan non-repudiation—dengan membandingkan tingkat pemenuhan pada model tradisional dan Zero Trust menggunakan skala kualitatif 1 (rendah) hingga 5 (sangat tinggi) berdasarkan sintesis temuan literatur yang dianalisis.

Aspek Keamanan	Skor Model Tradisional (1–5)	Skor Zero Trust Architecture (1–5)
Confidentiality (Kerahasiaan)	2	5
Integrity (Integritas)	3	5
Availability (Ketersediaan)	3	4
Authentication (Autentikasi)	2	5
Authorization (Otorisasi)	2	5
Accountability (Akuntabilitas)	2	4
Non-repudiation (Nirsangkal)	2	4

Tabel 7. Evaluasi Komparatif Efektivitas Keamanan Berdasarkan Aspek CIA Triad dan Prinsip Keamanan Lanjutan

Hasil evaluasi menunjukkan peningkatan paling signifikan terjadi pada aspek autentikasi dan otorisasi, sejalan dengan penekanan ZTA pada verifikasi identitas yang berkelanjutan dan kontrol akses granular berbasis kebijakan dinamis (Matiushin & Korkhov, 2023; Otta et al., 2023). Peningkatan pada aspek akuntabilitas dan non-repudiation terutama didorong oleh kemampuan pencatatan log yang lebih granular pada setiap titik penegakan kebijakan (PEP), yang menghasilkan jejak audit lebih rinci dibandingkan pencatatan log terbatas pada titik masuk perimeter dalam model tradisional.

3.10 Perbandingan dengan Penelitian Terdahulu

Temuan penelitian ini secara umum konsisten dengan hasil kajian sistematis literatur yang dilakukan oleh Syed et al. (2022), yang mengidentifikasi identity governance, micro-segmentation, dan software-defined perimeter sebagai tiga pilar utama implementasi ZTA. Penelitian ini memperluas temuan tersebut dengan menambahkan pemetaan eksplisit terhadap kerangka kerja ISO/IEC 27001:2022 dan NIST CSF 2.0 yang belum menjadi fokus utama pada kajian tersebut.

Buck et al. (2021) melalui tinjauan literatur multivokal mengidentifikasi bahwa penelitian ZTA pada masa awal cenderung berfokus pada aspek teknis implementasi tanpa memberikan perhatian memadai terhadap dimensi organisasional dan kesenjangan riset terkait metrik evaluasi efektivitas. Penelitian ini berupaya menjembatani kesenjangan tersebut melalui penyusunan matriks evaluasi efektivitas berbasis CIA Triad dan prinsip keamanan lanjutan sebagaimana disajikan pada Tabel 7.

Sejalan dengan temuan Adahman et al. (2022) yang menganalisis efektivitas biaya (cost-effectiveness) penerapan Zero Trust Architecture, penelitian ini juga mengonfirmasi bahwa manfaat keamanan yang diperoleh dari ZTA—khususnya pada aspek mitigasi insider threat dan pergerakan lateral—sebanding dengan kompleksitas implementasi yang harus dihadapi organisasi, terutama pada tahap awal transformasi arsitektur.

Dhiman et al. (2024) melalui analisis komparatif pendekatan model jaringan zero trust menegaskan bahwa micro-segmentation berbasis Software Defined Networking merupakan teknik yang paling banyak diadopsi pada lingkungan cloud, sejalan dengan hasil pemetaan framework pada penelitian ini yang menempatkan micro-segmentation sebagai kontrol prioritas kedua setelah manajemen identitas (Tabel 6).

Otta et al. (2023) dalam survei sistematis mengenai multi-factor authentication pada infrastruktur cloud menemukan bahwa kombinasi faktor biometrik tanpa memerlukan perangkat keras tambahan berpotensi menjadi solusi optimal untuk autentikasi berkelanjutan pada lingkungan

cloud multi-penyewa (multi-tenant), sebuah temuan yang memperkuat urgensi continuous authentication sebagai komponen inti ZTA sebagaimana dibahas pada bagian 3.3 penelitian ini.

Matiushin dan Korkhov (2023) melakukan analisis komparatif terhadap berbagai metode autentikasi berkelanjutan dan menyimpulkan bahwa belum terdapat satu metode tunggal yang optimal untuk seluruh konteks penggunaan, melainkan diperlukan kombinasi metode yang disesuaikan dengan tingkat sensitivitas sumber daya yang dilindungi—sebuah wawasan yang relevan dengan pendekatan berjenjang (tiered) yang direkomendasikan pada roadmap implementasi penelitian ini (Tabel 8).

Tyler dan Viana (2021) mengembangkan kerangka bantu transisi ZTA khusus untuk organisasi layanan kesehatan dan menemukan bahwa kompleksitas regulasi menjadi hambatan signifikan dalam adopsi ZTA pada sektor dengan tingkat kepatuhan tinggi. Temuan ini memberikan konteks tambahan bahwa kecepatan adopsi ZTA sebagaimana dipetakan pada roadmap penelitian ini perlu disesuaikan dengan konteks regulasi sektoral organisasi yang mengadopsinya.

Ahmadi (2024) dan Ajish (2024) sama-sama menyoroti peran kecerdasan buatan dalam memperkuat kemampuan deteksi anomali pada ZTA, khususnya dalam konteks continuous monitoring pada lingkungan cloud berskala besar. Penelitian ini sejalan dengan temuan tersebut namun menempatkan integrasi kecerdasan buatan sebagai aspek pengembangan lanjutan (roadmap jangka panjang) mengingat kompleksitas dan kematangan organisasional yang dibutuhkan untuk mengadopsinya secara efektif.

He et al. (2022) mengidentifikasi bahwa tantangan utama implementasi ZTA bukan hanya bersifat teknis, melainkan juga mencakup resistensi organisasional dan kebutuhan investasi awal yang signifikan—sebuah temuan yang menegaskan pentingnya pendekatan implementasi bertahap sebagaimana direkomendasikan dalam penelitian ini, alih-alih transformasi menyeluruh secara sekaligus (big-bang implementation).

Secara keseluruhan, penelitian ini menunjukkan persamaan mendasar dengan penelitian-penelitian terdahulu dalam mengonfirmasi superioritas ZTA dibandingkan model perimeter tradisional pada hampir seluruh dimensi keamanan yang dievaluasi. Perbedaan utama terletak pada cakupan penelitian ini yang mengintegrasikan analisis risiko kuantitatif-kualitatif dengan pemetaan silang empat kerangka kerja sekaligus dalam satu model evaluasi yang koheren, serta penyusunan roadmap implementasi bertahap yang eksplisit—sebuah kontribusi yang relatif jarang ditemukan secara terintegrasi pada penelitian-penelitian sebelumnya yang cenderung berfokus pada satu kerangka kerja atau satu domain aplikasi tertentu.

3.11 Rekomendasi Implementasi dan Roadmap

Berdasarkan hasil analisis risiko, perbandingan model, dan evaluasi efektivitas, penelitian ini merumuskan rekomendasi implementasi Zero Trust Architecture yang disusun dalam tiga tahapan roadmap sebagaimana disajikan pada Tabel 8. Roadmap ini disusun dengan mempertimbangkan prinsip implementasi bertahap yang meminimalkan gangguan operasional sekaligus memaksimalkan pengurangan risiko secara progresif, sejalan dengan pendekatan maturity model yang direkomendasikan oleh Cybersecurity and Infrastructure Security Agency (CISA) dan praktik terbaik CIS Controls v8.

Tahapan Roadmap	Aktivitas Utama	Kerangka Kerja Acuan
Jangka Pendek (0–6 bulan)	Implementasi MFA menyeluruh pada seluruh titik akses kritis; inventarisasi dan klasifikasi aset serta data; penerapan kebijakan least privilege pada akun dengan hak istimewa (privileged accounts); audit konfigurasi cloud	NIST SP 800-207 (Identity Pillar), CIS Controls 5 & 6, ISO/IEC 27001:2022 Annex A.5.15–A.5.16
Jangka Menengah (6–18 bulan)	Penerapan micro-segmentation pada jaringan dan beban kerja kritis; deployment Policy Enforcement Point pada lapisan aplikasi; integrasi continuous monitoring dan User and Entity Behavior Analytics (UEBA)	NIST SP 800-207 (Network & Application Pillar), CIS Controls 12, 13, 16, NIST CSF 2.0 (Detect Function)
Jangka Panjang (18–36 bulan)	Otomasi orkestrasi kebijakan berbasis machine learning; integrasi penuh Policy Decision Point lintas seluruh lini aplikasi dan cloud provider; pengukuran maturitas ZTA secara berkelanjutan dan audit kepatuhan menyeluruh	NIST SP 800-207A (Multi-cloud), NIST CSF 2.0 (Respond & Recover), ISO/IEC 27001:2022 Klausul 9–10

Tabel 8. Roadmap Implementasi Zero Trust Architecture Jangka Pendek, Menengah, dan Panjang

Rekomendasi ini menekankan bahwa keberhasilan implementasi ZTA tidak hanya bergantung pada penerapan teknologi, tetapi juga memerlukan komitmen organisasional dalam hal tata kelola, alokasi sumber daya, dan perubahan budaya keamanan menuju verifikasi eksplisit yang berkelanjutan. Organisasi disarankan untuk memulai implementasi dari domain dengan tingkat risiko tertinggi sebagaimana teridentifikasi pada Tabel 2 dan Tabel 4, guna memaksimalkan pengurangan risiko pada tahap awal implementasi dengan sumber daya yang tersedia.

4. KESIMPULAN

Penelitian ini menyimpulkan bahwa Zero Trust Architecture menawarkan pendekatan keamanan yang secara signifikan lebih adaptif dibandingkan model keamanan perimeter tradisional dalam menghadapi lanskap ancaman kontemporer yang ditandai oleh meningkatnya ransomware, kebocoran data, insider threat, serta kompleksitas keamanan pada lingkungan komputasi awan dan kerja jarak jauh. Prinsip “never trust, always verify” yang menjadi landasan ZTA, dipadukan dengan komponen-komponen seperti manajemen identitas dan akses, autentikasi multifaktor, prinsip least privilege, segmentasi mikro, dan pemantauan berkelanjutan, terbukti mampu meningkatkan efektivitas keamanan secara signifikan pada aspek autentikasi, otorisasi, dan akuntabilitas berdasarkan hasil analisis komparatif yang dilakukan.

Hasil pemetaan lintas kerangka kerja NIST SP 800-207, ISO/IEC 27001:2022, NIST CSF 2.0, dan CIS Controls v8 menunjukkan bahwa keempat kerangka kerja tersebut bersifat saling melengkapi dan dapat diintegrasikan dalam satu strategi implementasi yang koheren. Roadmap implementasi bertahap yang dirumuskan dalam penelitian ini—mencakup tahapan jangka pendek, menengah, dan panjang—diharapkan dapat menjadi acuan praktis bagi organisasi dalam merancang transisi menuju arsitektur tanpa kepercayaan implisit secara terukur dan berkelanjutan.

Penelitian ini memiliki keterbatasan berupa pendekatan kualitatif berbasis studi literatur yang belum divalidasi melalui implementasi empiris pada studi kasus organisasi tertentu. Penelitian selanjutnya disarankan untuk melakukan validasi empiris melalui studi kasus implementasi ZTA pada sektor industri spesifik, disertai pengukuran kuantitatif terhadap indikator kinerja keamanan sebelum dan sesudah implementasi, guna memperkuat generalisasi temuan penelitian ini.

DAFTAR PUSTAKA

- Abdulsalam, Y. S., & Hedabou, M. (2022). Security and privacy in cloud computing: Technical review. *Future Internet*, 14(1), 11. <https://doi.org/10.3390/fi14010011>
- Adahman, Z., Malik, A. W., & Anwar, Z. (2022). An analysis of zero-trust architecture and its cost-effectiveness for organizational security. *Computers & Security*, 122, 102911. <https://doi.org/10.1016/j.cose.2022.102911>
- Ahmadi, S. (2024). Zero Trust Architecture in cloud networks: Application, challenges and future opportunities. *Journal of Engineering Research and Reports*, 26(2), 215–228. <https://doi.org/10.9734/jerr/2024/v26i21083>
- Ahmed, H. A. S., Ali, M. H., Kadhun, L. M., Zolkipli, M. F., & Alsariera, Y. A. (2022). Software-as-a-Service security challenges and best practices: A multivocal literature review. *Applied Sciences*, 12(8), 3953. <https://doi.org/10.3390/app12083953>
- Ajish, D. (2024). The significance of artificial intelligence in zero trust technologies: A comprehensive review. *Journal of Electrical Systems and Information Technology*, 11, Article 34. <https://doi.org/10.1186/s43067-024-00155-z>
- Alkhalil, Z., Hewage, C., Nawaf, L., & Khan, I. (2021). Phishing attacks: A recent comprehensive study and a new anatomy. *Frontiers in Computer Science*, 3, 563060. <https://doi.org/10.3389/fcomp.2021.563060>
- Alsharif, M., Mishra, S., & AlShehri, M. (2022). Impact of human vulnerabilities on cybersecurity. *Computer Systems Science and Engineering*, 40(3), 1153–1166. <https://doi.org/10.32604/csse.2022.019938>
- Bin Sarhan, B., & Altwaijry, N. (2023). Insider threat detection using machine learning approach. *Applied Sciences*, 13(1), 259. <https://doi.org/10.3390/app13010259>

- Buck, C., Olenberger, C., Schweizer, A., Völter, F., & Eymann, T. (2021). Never trust, always verify: A multivocal literature review on current knowledge and research gaps of zero-trust. *Computers & Security*, 110, 102436. <https://doi.org/10.1016/j.cose.2021.102436>
- Center for Internet Security. (2021). CIS Controls Version 8. Center for Internet Security.
- Chandramouli, R., & Butcher, Z. (2023). A zero trust architecture model for access control in cloud-native applications in multi-location environments (NIST Special Publication 800-207A). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-207A>
- Dhiman, P., Kaur, A., Balasaraswathi, V. R., Gulzar, Y., Alwan, A. A., & Hamid, Y. (2024). A review and comparative analysis of relevant approaches of zero trust network model. *Sensors*, 24(4), 1328. <https://doi.org/10.3390/s24041328>
- Greenwood, D. (2021). Applying the principles of zero-trust architecture to protect sensitive and critical data. *Network Security*, 2021(6), 7–9. [https://doi.org/10.1016/S1353-4858\(21\)00065-1](https://doi.org/10.1016/S1353-4858(21)00065-1)
- He, Y., Huang, D., Chen, L., Ni, Y., & Ma, X. (2022). A survey on zero trust architecture: Challenges and future trends. *Wireless Communications and Mobile Computing*, 2022, Article 6476274. <https://doi.org/10.1155/2022/6476274>
- International Organization for Standardization. (2022). ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements. ISO.
- International Organization for Standardization. (2022). ISO/IEC 27002:2022 – Information security, cybersecurity and privacy protection – Information security controls. ISO.
- Khan, M. J. (2023). Zero trust architecture: Redefining network security paradigms in the digital age. *World Journal of Advanced Research and Reviews*, 19(3), 105–116.
- Lallie, H. S., Shepherd, L. A., Nurse, J. R. C., Erola, A., Epiphaniou, G., Maple, C., & Bellekens, X. (2021). Cyber security in the age of COVID-19: A timeline and analysis of cyber-crime and cyber-attacks during the pandemic. *Computers & Security*, 105, 102248. <https://doi.org/10.1016/j.cose.2021.102248>
- Matiushin, I., & Korkhov, V. (2023). Continuous authentication methods for zero-trust cybersecurity architecture. In O. Gervasi et al. (Eds.), *Computational Science and Its Applications – ICCSA 2023 Workshops (LNCS Vol. 14109, pp. 1–15)*. Springer. https://doi.org/10.1007/978-3-031-37120-2_22
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.29>
- Otta, S. P., Panda, S., Gupta, M., & Hota, C. (2023). A systematic survey of multi-factor authentication for cloud infrastructure. *Future Internet*, 15(4), 146. <https://doi.org/10.3390/fi15040146>

- Phiayura, P., & Teerakanok, S. (2023). A comprehensive framework for migrating to zero trust architecture. *IEEE Access*, 11, 19487–19511. <https://doi.org/10.1109/ACCESS.2023.3248622>
- Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero trust architecture (NIST Special Publication 800-207). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-207>
- Soni, A., Nanda, S. K., Priyadarshini, R., & Panda, G. (2026). A comprehensive review and comparative analysis of zero trust architecture: Evolution, implementation strategies, and key challenges. *Journal of Computer Security*, 34(2), 85–110. <https://doi.org/10.1177/0926227X251409922>
- Syed, N. F., Shah, S. W., Shaghaghi, A., Anwar, A., Baig, Z., & Doss, R. (2022). Zero trust architecture (ZTA): A comprehensive survey. *IEEE Access*, 10, 57143–57179. <https://doi.org/10.1109/ACCESS.2022.3174679>
- Tyler, D., & Viana, T. (2021). Trust no one? A framework for assisting healthcare organisations in transitioning to a zero-trust network architecture. *Applied Sciences*, 11(16), 7499. <https://doi.org/10.3390/app11167499>